

Cybersecurity Daily Newsletter

Vol. 003 | 2026-07-23 09:00 WIB

Top 5 Highlights

- wp2shell hits WordPress: detecting pre-auth RCE from plugin drop to command execution
- New ransomware group uses printers to deliver ransom notes
- Stadler Rail refuses to pay \$12.3 million ransom after ransomware attack
- North Korean hackers target South Korean software vendors
- Arista Networks enhances SD-WAN with AI-infused edge threat management

Threat Intelligence (10)

01. Attackers Are Learning to Live Off the AI Toolchain

Sandworm_Mode is an early example of malware that exploits trusted AI tools and workflows to make malicious activity virtually indistinguishable from normal activity.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.darkreading.com/cyber-risk/attackers-live-off-ai-toolchain>

02. Next chapter: Restructuring GitHub's bug bounty program

GitHub is making some significant changes to its bug bounty program, shifting its focus to give researchers a better experience working with the GitHub team. The post Next chapter: Restructuring GitHub's bug bounty program appeared first on The GitHub Blog .

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://github.blog/security/next-chapter-restructuring-githubs-bug-bounty-program/>

03. TrickBot Ditches HTTP for DNS Tunneling in Latest Variant

New TrickBot variant hides C2 communication inside DNS queries, replacing decade-old HTTP pattern

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.infosecurity-magazine.com/news/trickbot-dns-tunneling-c2/>

04. Why Modern SOCs Need Multi-Layered Detections

The cycle is over. For years, cybersecurity followed a familiar pattern: defenses improved, attackers adapted, and the back-and-forth continued. Today, AI-equipped attackers are simply outpacing defenses. Most intrusions now bypass endpoint and malware-based detection entirely. The CrowdStrike Global Threat Report estimates around 79% of attacks are malware...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/07/why-modern-socs-need-multi-layered.html>

05. [+24h Old] Trojanized Newtonsoft.Json Fork Hides Game-Rigging Code in a Working Library

Cybersecurity researchers have discovered a NuGet typosquat that's unlike the typical information-stealing malware distributed via package registries: usual info-stealers: it's designed to rig live game results on Digitain. The package, named "Newtonsoftt.Json.Net," masquerades as the Newtonsoft.Json library and is a trojanized fork. Seven versions of the p...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/07/trojanized-newtonsoftjson-fork-hides.html>

06. [+24h Old] ISC Stormcast For Wednesday, July 22nd, 2026 <https://isc.sans.edu/podcastdetail/10018>, (Wed, Jul 22nd)

ISC Stormcast For Wednesday, July 22nd, 2026 <https://isc.sans.edu/podcastdetail/10018>, (Wed, Jul 22nd)

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://isc.sans.edu/diary/rss/33174>

07. [+24h Old] FakeGit campaign uses 7,600 GitHub repos to push SmartLoader malware

A large-scale operation dubbed 'FakeGit' is pushing SmartLoader and StealC malware through 7,600 malicious GitHub repositories that accumulated more than 14 million downloads. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.bleepingcomputer.com/news/security/fakegit-campaign-uses-7-600-github-repos-to-push-smartloader-malware/>

08. [+24h Old] Captive Portal Detection, (Tue, Jul 21st)

Not everything our honeypots detect is an attack. Sometimes it is just "odd traffic", and this is one example: Our "First Seen" list currently includes "<http://detectportal.firefox.co>

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://isc.sans.edu/diary/rss/33172>

09. [+24h Old] Your AI agent's config is now the payload: How attackers are targeting the developer agent harness

Attackers have shifted from hiding from AI tools to running inside them. By poisoning the config files that govern AI coding assistants, a new worm class achieves silent persistence, evades AI-based scanners, and spreads across an organization's repositories through developers' own tools. Key takeaways AI coding assistant configuration files, such as settin...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.tenable.com/blog/ai-coding-assistant-agent-harness-attacks>

10. [+24h Old] New ClickLock Stealer locks your Mac until you hand over your password

A new macOS infostealer tricks victims into revealing their system password and installs a persistent backdoor for future access.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.malwarebytes.com/blog/news/2026/07/new-clicklock-stealer-locks-your-mac-until-you-hand-over-your-password>

Latest Vulnerabilities (10)

01. wp2shell hits WordPress: detecting pre-auth RCE from plugin drop to command execution

We ran the wp2shell WordPress RCE chain end-to-end with Elastic Defend. Detection rule walkthrough, IOCs, and hunt guidance.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.elastic.co/security-labs/wp2shell-wordpress-rce-detection-elastic-defend>

02. North Korean hackers target South Korean software vendors

The Kimsuky group compromised a groupware vendor through an externally accessible mail server by exploiting a remote code execution vulnerability.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.scworld.com/brief/north-korean-hackers-target-south-korean-software-vendors>

03. Arista Networks enhances SD-WAN with AI-infused edge threat management

The Edge Threat Management (ETM) for VeloCloud SD-WAN packages zero trust branch office security with a common operating system, a uniform enforcement engine, and standardized security policies.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.scworld.com/brief/arista-networks-enhances-sd-wan-with-ai-infused-edge-threat-management>

04. Hugging Face ‘attacker’ revealed to be OpenAI agents that escaped testing sandbox

OpenAI said GPT-5.6 Sol and a pre-release model exploited vulnerabilities to “cheat” on ExploitGym.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.scworld.com/news/hugging-face-attacker-revealed-to-be-openai-agents-that-escaped-testing-sandbox>

05. Critical Zimbra security update fixes 9 vulnerabilities

Business email and collaboration suite Zimbra has received a major security update that fixes several critical issues that could allow attackers to execute malicious code on the server or in users’ browsers. Available in commercial and open-source editions, Zimbra Collaboration Suite is a self-hosted Microsoft Exchange alternative that is popular with busin...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources:

<https://www.csoononline.com/article/4200221/critical-zimbra-security-update-fixes-9-vulnerabilities.html>

06. Fake Bahrain Alert App Deploys Android Surveillance Malware

A malicious application delivers four-stage Android spyware via phony Google Play sites, exploiting civilian fear during Iranian missile strikes.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources:

<https://www.darkreading.com/mobile-security/fake-bahrain-alert-apps-android-surveillance-malware>

07. AI Threat Detection Is Not Enough Without Adversary Intelligence

The 2026 emergence of Anthropic's Claude Mythos Preview showed security leaders that AI can now find software vulnerabilities faster than the humans responsible for patching them.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.intel471.com/blog/ai-threat-detection-is-not-enough-without-adversary-intelligence>

08. Oracle's July update fixes ten 10.0 vulnerabilities in Fusion Middleware

Oracle's July 2026 Critical Patch Update, its largest ever, contains 1,449 new security patches spanning 32 product families, from Oracle Database and E-Business Suite to PeopleSoft, GoldenGate, Java SE, and Fusion Middleware. Fusion Middleware was particularly hard hit, with new security patches for 355 security vulnerabilities, 219 of them remotely exploi...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.csoonline.com/article/4200184/oracles-july-update-fixes-ten-10-0-vulnerabilities-in-fusion-middleware.html>

09. Ubuntu snap-confine Flaw Could Give Local Users Root on Default Desktop Installs

Cybersecurity researchers have disclosed details of a new local privilege escalation (LPE) vulnerability in snap-confine that an unprivileged user can trigger to obtain root access and gain complete control of a target environment. The high-severity flaw, tracked as CVE-2026-8933 (CVSS score: 7.8), impacts default installations of Ubuntu Desktop 24.04, 25.1...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://thehackernews.com/2026/07/ubuntu-snap-confine-flaw-could-give.html>

10. VU#847406: Duplicati backup software v2.3.0.1 is vulnerable to an incorrect permission assignment vulnerability

Overview Duplicati v2.3.0.1 is vulnerable to arbitrary code execution when installed outside the default C:\Program Files\Duplicati 2\ directory. An attacker with local user privileges who can write files to the Duplicati installation directory can execute arbitrary code by placing malicious files, such as DLLs, in that directory. To mitigate this vulnerability...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://kb.cert.org/vuls/id/847406>

Data Breach & Cybercrime (10)

01. New ransomware group uses printers to deliver ransom notes

The newly identified group, "XEntry Team," is reportedly behind these attacks.

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.scworld.com/brief/new-ransomware-group-uses-printers-to-deliver-ransom-notes>

02. Stadler Rail refuses to pay \$12.3 million ransom after ransomware attack

The incident, which occurred in mid-July, involved the theft of non-security-relevant technical information from a supplier.

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources:

<https://www.scworld.com/brief/stadler-rail-refuses-to-pay-12-3-million-ransom-after-ransomware-attack>

03. Upbound says hack caused \$13 million in fraudulent Acima leases

The Upbound Group fintech company disclosed that threat actors who stole data from its systems leveraged it to create \$13 million in Acima leases. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/upbound-says-hack-caused-13-million-in-fraudulent-acima-leases/>

04. South Korea discloses data breach impacting diplomats worldwide

South Korea disclosed that hackers breached the National Diplomatic Academy's online education system for ten months and stole personal information belonging to current and former employees of the Ministry of Foreign Affairs (MFA), including overseas diplomats. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/south-korea-discloses-data-breach-impacting-diplomats-worldwide/>

05. Swiss rail giant Stadler rejects \$12.3M ransom demand after cyberattack

Swiss rail vehicle manufacturer Stadler Rail says the Everest ransomware gang demanded about \$12.3 million after breaching a data exchange platform shared with one of its suppliers. [...]

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.bleepingcomputer.com/news/security/swiss-rail-giant-stadler-rejects-123m-ransom-demand-after-cyberattack/>

06. How enterprise GenAI can amplify ransomware risk - and how to contain it

Enterprise AI can accelerate ransomware attacks when AI assistants and agents inherit excessive permissions or compromised identities. Acronis explains how identity controls, governance, and least-privilege access help reduce AI-enabled ransomware risk while supporting secure AI adoption. [...]

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.bleepingcomputer.com/news/security/how-enterprise-genai-can-amplify-ransomware-risk-and-how-to-contain-it/>

07. Suno, Paidwork Data Breaches Affect Tens of Millions of Accounts

Hackers leaked names, email addresses, phone numbers, passwords, and financial information stolen from the two platforms. The post Suno, Paidwork Data Breaches Affect Tens of Millions of Accounts appeared first on SecurityWeek .

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.securityweek.com/suno-paidwork-data-breaches-affect-tens-of-millions-of-accounts/>

08. Chick-fil-A loyalty accounts hijacked using stolen passwords

If you have a Chick-fil-A One account, now is a good time to change your password-and make sure it's one you don't use anywhere else.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.malwarebytes.com/blog/data-breaches/2026/07/chick-fil-a-loyalty-accounts-hijacked-using-stolen-passwords>

09. Open AI Claims Its AI Models Went Rogue and Hacked Another Company

Hugging Face recently disclosed a security breach. OpenAI has now said that it was its AI models which broke containment and hacked Hugging Face themselves

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.infosecurity-magazine.com/news/open-ai-hacked-another-company/>

10. Paidwork breach exposes data of 23 million users: Check if you're affected

A reported breach at microtask platform Paidwork exposed personal and financial data of more than 23 million users. Here's how to check if you're affected.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.malwarebytes.com/blog/data-breaches/2026/07/paidwork-breach-exposes-data-of-23-million-users-check-if-youre-affected>